

Manual 14 - Implementación Controlada PCI DSS v4.0.1

Authority boundary: practical implementation guidance based on the current PCI SSC source state. This is not PCI SSC endorsement, certification, an official translation, legal advice, or a substitute for required qualified validation.

Manual 14 — PCI DSS Implementation Paths

Essential path

For smaller or lower-complexity environments that still require disciplined PCI DSS scoping and evidence. Minimum outputs: CDE scope statement, data-flow diagram, asset inventory, responsibility matrix, core configuration standards, access/MFA evidence, vulnerability evidence, logging evidence, incident-response evidence, third-party attestations, and remediation register.

Structured path

For organizations with multiple applications, service providers, business units, or formal compliance operations. Adds control ownership, evidence calendars, change-driven reassessment, service-provider dependency mapping, secure-development evidence, penetration-test governance, exception/compensating-control records, and management reporting.

Enhanced path

For complex enterprises, high transaction volumes, hybrid/multi-cloud environments, extensive third-party dependencies, or environments requiring continuous assurance. Adds automated evidence collection where appropriate, continuous control monitoring, risk-based sampling, dependency graphing, control-health metrics, integrated GRC workflows, and formal management assurance.

Evidence object schema

Every control implementation should record:

- requirement/control objective
- applicability and scope
- accountable owner

- responsible operator
- implementation procedure
- operating frequency
- evidence artifact
- evidence repository/location
- retention expectation
- reviewer/test procedure
- result/status
- exception or compensating-control reference
- remediation owner/date
- reassessment trigger

Decision controls

The controlled manual must explicitly separate:

- defined approach vs customized approach where applicable;
- underlying security requirements vs SAQ/ROC/AOC validation instruments;
- PCI DSS requirements vs adjacent PCI standards;
- PCI DSS obligations vs contractual/acquirer/payment-brand requirements;
- PCI DSS requirements vs jurisdiction-specific law;
- technical remediation vs formal exception/compensating-control governance.

Publication rule

Implementation-path maturity must never be represented as certification status. Publication requires exact-candidate QA, durable artifacts, provenance, release-registry reconciliation, and sequential predecessor clearance.

Manual 14 — Implementación Controlada PCI DSS v4.0.1

Chapter 01 — Gobierno y modelo operativo PCI DSS

Establezca un modelo operativo con patrocinio ejecutivo, responsable del programa, dueños de controles, operadores, revisores y rutas de escalamiento. Mantenga calendario, registro de decisiones, inventario de evidencias, registro de remediación y proceso de reevaluación por cambios.

Chapter 02 — Aplicabilidad y límites de entidad/validación

Determine por qué aplica PCI DSS, qué entidades y entornos están dentro de alcance y qué ruta de validación corresponde. Separe requisitos PCI DSS de obligaciones contractuales, del adquirente, marcas de pago y leyes jurisdiccionales.

Chapter 03 — Datos de cuenta y límites de protección

Clasifique datos de cuenta, incluido PAN y datos sensibles de autenticación, y defina patrones permitidos de recolección, procesamiento, transmisión, visualización y almacenamiento. Mantenga reglas de retención, eliminación, enmascaramiento, truncamiento y protección criptográfica.

Chapter 04 — Alcance y límites del CDE

Defina el entorno de datos del titular de tarjeta y sistemas conectados o capaces de afectar su seguridad. Use procedimientos repetibles que consideren redes, identidades, administración, servicios compartidos, nube, herramientas de seguridad y terceros.

Chapter 05 — Flujos de datos y segmentación

Mantenga diagramas actuales de flujos de pago y datos de cuenta. Cuando la segmentación reduzca alcance, documente objetivo, puntos de control, dependencias administrativas, método de prueba y evidencia de efectividad continua.

Chapter 06 — Roles, validación y aseguramiento

Defina responsabilidades de gestión, operación, aseguramiento interno, QSA/ISA, ASV, adquirente y marcas de pago. Distinga SAQ, ROC y AOC de los requisitos de seguridad subyacentes.

Chapter 07 — Enfoques definido, personalizado y controles compensatorios

Identifique el enfoque aplicable para cada requisito. Para controles compensatorios, documente restricción, objetivo, riesgo, diseño, validación, aprobación, vencimiento/reevaluación y evidencia.

Chapter 08 — Arquitectura de evidencia y rutas de implementación

Use rutas Esencial, Estructurada y Mejorada para escalar rigor operativo sin alterar obligaciones. Cada objeto de evidencia debe indicar objetivo, alcance, dueño, procedimiento, frecuencia, artefacto, ubicación, retención, revisión/prueba, resultado, excepción/remediación y disparador de reevaluación.

Chapter 09 — Controles de seguridad de red

Defina controles de red alrededor del CDE y entornos conectados mediante arquitectura aprobada, estándares de configuración, control de cambios, revisión de reglas y evidencia retenida.

Chapter 10 — Configuraciones seguras

Mantenga estándares endurecidos para componentes en alcance y gestione desviaciones mediante excepciones controladas. Conserve línea base, estado, cambios, revisiones y verificación.

Chapter 11 — Protección de datos de cuenta almacenados

Minimice almacenamiento y conserve datos solo por necesidades documentadas. Aplique enmascaramiento, truncamiento, cifrado, gestión de claves y eliminación según corresponda.

Chapter 12 — Criptografía en transmisión

Proteja datos de cuenta en redes abiertas o públicas con protocolos y configuraciones criptográficas aprobadas y vigentes. Mantenga inventarios de flujos, configuraciones y validación periódica.

Chapter 13 — Defensas contra malware

Identifique sistemas expuestos a riesgo de malware e implemente prevención, detección, monitoreo, actualización y respuesta. Documente decisiones de aplicabilidad y su reevaluación.

Chapter 14 — Sistemas y software seguros

Integre prevención de vulnerabilidades, codificación segura, cambios, segregación de funciones, pruebas y aprobación de liberaciones al ciclo de desarrollo, incluyendo dependencias de comercio electrónico cuando correspondan.

Chapter 15 — Gestión de vulnerabilidades

Opere un ciclo de descubrimiento, evaluación de riesgo, priorización, dueño, remediación, excepción, nueva prueba y métricas. La salida de herramientas es insumo de evidencia, no prueba de cumplimiento por sí sola.

Chapter 16 — Control de cambios y aseguramiento de configuración

Exija solicitud, impacto, autorización, pruebas, implementación, reversa y verificación posterior para cambios materiales. Incluya implicaciones de alcance PCI.

Chapter 17 — Modelo de control de acceso

Otorgue acceso por necesidad de negocio, mínimo privilegio, roles y segregación de funciones. Mantenga evidencias de altas, cambios, bajas, privilegios y revisiones periódicas.

Chapter 18 — Identidad, autenticación y MFA

Mantenga ciclos de identidad, estándares de autenticación, MFA, cuentas de servicio, secretos y controles privilegiados. Evidencie alta, configuración, revisión, revocación y respuesta a anomalías.

Chapter 19 — Acceso físico

Controle acceso físico a instalaciones, sistemas, medios y áreas relevantes. Mantenga evidencias de visitantes, credenciales, medios, eliminación y revisiones según aplique.

Chapter 20 — Registro y monitoreo

Defina fuentes de logs, recolección, sincronización, retención, revisión, alertas, escalamiento y ubicaciones de evidencia. Demuestre operación e investigación de eventos significativos.

Chapter 21 — Pruebas de seguridad

Mantenga programa de escaneo, pruebas de penetración, validación de segmentación, evaluación inalámbrica cuando aplique y otras pruebas requeridas, con alcance, independencia, frecuencia, evidencia, remediación y nueva prueba.

Chapter 22 — Escaneos externos y límites ASV

Distinga escaneos internos de preparación de resultados oficiales ASV cuando correspondan. Herramientas abiertas o comerciales no sustituyen validación calificada.

Chapter 23 — Pruebas de penetración y validación de segmentación

Defina objetivo, alcance, independencia/competencia, metodología, tratamiento de resultados, remediación y nueva prueba. Verifique segmentación contra rutas realistas y dependencias administrativas.

Chapter 24 — Proveedores de servicio y evidencia de terceros

Inventaríe proveedores que almacenen, procesen, transmitan, protejan o puedan afectar datos de cuenta. Mantenga matrices de responsabilidad, compromisos, atestaciones, descripción del servicio, dependencias y monitoreo.

Chapter 25 — Respuesta a incidentes

Mantenga y pruebe un plan para eventos de pago/datos de cuenta con roles, comunicaciones, preservación de evidencia, contención, recuperación, dependencias de notificación y lecciones aprendidas.

Chapter 26 — Excepciones y controles compensatorios

Use un proceso gobernado con justificación, objetivo afectado, evaluación de riesgo, aprobador, vencimiento, evidencia, monitoreo y remediación. No convierta excepciones en renunciaciones silenciosas.

Chapter 27 — Operación de la ruta de validación

Prepare la ruta aplicable usando inventario de evidencias, matriz de dueños, seguimiento de problemas y controles de calidad, separando preparación de SAQ/ROC/AOC de la operación real de controles y del juicio del evaluador.

Chapter 28 — Cumplimiento continuo y monitoreo de controles

Programe actividades y evidencias durante todo el año. Controle salud, faltantes, evidencia obsoleta, excepciones, cambios y envejecimiento de remediaciones.

Chapter 29 — Remediación y nueva prueba

Para cada hallazgo mantenga dueño, causa raíz cuando sea práctico, plan, fecha, tratamiento interino, evidencia de cierre y resultado de nueva prueba. El cierre requiere verificación objetiva.

Chapter 30 — Aseguramiento y reporte a la dirección

Reporte alcance, salud de controles, hallazgos abiertos, excepciones, terceros, actividades próximas y cambios materiales. Documente aceptación de riesgo y escalamiento.

Chapter 31 — Progresión de madurez y capacidad

Evolucione de recopilación reactiva de evidencia a aseguramiento repetible, medido y más automatizado. La madurez mejora calidad y oportunidad, pero no sustituye requisitos aplicables.

Chapter 32 — Escenarios de implementación y fallas

Use escenarios realistas de alcance, incidentes, escaneos fallidos, accesos anómalos, cambios de proveedor, migraciones a nube, comercio electrónico, fallas de segmentación y brechas de evidencia. Registre lecciones y mejoras.